



**FATEC – FACULDADE DE TECNOLOGIA DE SÃO CAETANO DO SUL
ANTÔNIO RUSSO**

Proposta de Arquitetura de Cibersegurança em Camadas Baseada no Framework NIST

Efraim de Almeida Lima

**Abril – 2026
SÃO CAETANO - SP**

ÍNDICE

1. Introdução
2. Camada de Borda e Mitigação Externa (Edge Security)
3. Controle de Fronteira e Filtragem de Rede (Block List & Network Protection)
4. Domínio de Dados e Virtualização (Data Domain)
5. Monitoramento de Servidores e Estações (Data Domain)
6. Monitorização, Detecção e Resposta (SIEM, EDR & XDR)
7. Conclusão

1. Introdução

A evolução das ameaças cibernéticas exige que as organizações abandonem modelos de segurança baseados apenas no perímetro físico. Esta arquitetura adota o conceito de **Defesa em Profundidade**, segmentando a infraestrutura em camadas lógicas que garantem redundância e granularidade no controlo de acessos.

2. Camada de Borda e Mitigação Externa (Edge Security)

A primeira barreira de defesa atua antes que o tráfego atinja a infraestrutura local, focando na disponibilidade e integridade do tráfego de entrada.

- **CDN & Edge Protection:** Implementação de Redes de Entrega de Conteúdo para distribuição de carga e ocultação do endereço IP real da origem.
 - Ocultação de Origem: Impedir que o IP do roteador de borda seja exposto publicamente;
 - Caching Estratégico: Reduzir a carga nos servidores internos servindo conteúdo estático na borda;
 - Anycast Network: Distribuir o tráfego globalmente para mitigar latência e ataques volumétricos.
- **Mitigação de DDoS:** Filtragem de tráfego em larga escala para garantir a disponibilidade, Este aqui estaria atrelado ao Firewall.
 - Mitigação de Camada 3, 4 e 7: Bloqueio de ataques de inundação (SYN, UDP flood) e ataques de exaustão de recursos HTTP;
 - - Reputação de IP Global: Bloqueio automático de IPs conhecidos por botnets antes de atingirem a rede local.
- **NG Firewall:** Implementar um NG Firewall para bloquear acessos dos usuários indevidos no ambiente
 - Para proteção de acesso
 - Listas de ACL
 - LDAP/RADIUS (Jogar pra autenticação local - Data Domain) -> consome recursos do roteador
 - 802.1X
 - IPS/IDS: Detecção e prevenção de intrusão baseada em assinaturas e anomalias;
 - Control application

3. Controle de Fronteira e Filtragem de Rede (Block List & Network Protection)

Esta camada é responsável pela inspeção técnica e lógica dos pacotes que atravessam o perímetro da organização.

- **Roteador de Borda:** Implementar um roteador de borda para filtrar pacotes maliciosos
 - Inspeção de pacotes (SPI)
 - criptografia de comunicação (VPN + MFA) para autenticação na caixa apenas,
 - controle de acesso (WPA3)
 - mensurar tempo de reboot, de patches update
- **NG Firewall:** Implementar um NG Firewall para bloquear acesso de sites específicos, protocolos e portas também. Sendo esta uma primeira barreira
 - Proxy para Acesso ao sistema
 - DPI (inspeção de pacotes) -> dinamica a partir do CTI
 - VPN + MFA
 - SPI (Stateful Packet Inspection): Monitoramento do estado das conexões ativas;
 - Hardening de Gerenciamento: Acesso à interface de configuração apenas via VPN + MFA;
 - Segurança de Camada 2: Implementação de WPA3 para conexões wireless administrativas.
- **WAF:** Garantir a segurança dos serviços presentes no ambiente, garantindo resistencia a ataques sofisticados
 - filtragem de trafego HTTP;HTTPS
 - bloqueio de ameaças OWASP TOP 10
 - gerenciamento de presença de BOTs;
 - mitigação de DDoS
 - segurança de APIs

- Analise Comportamental com IA;
- Serviços de Identidade: Integração com LDAP/RADIUS para aplicar políticas baseadas no usuário (Identity-Aware).

4. Domínio de Dados e Virtualização (Data Domain)

Estando dentro de Data Domain, nesta camada, o foco reside na proteção dos ativos onde a informação é processada e armazenada.

- **Virtualização e Contentores (Kubernetes/Docker):** Implementar virtualização para serviços específicos, aplicações de uso interno/externo, organização dos ambientes de desenvolvimento e de produção.
 - Servidores guest devidamente hardenizados
 - portas abertas estritamente necessárias,
 - serviços rodando apenas sendo os necessários,
 - não permitir root over ssh
 - acesso remoto apenas criptografado e com par de chaves,
 - containers em redes apartadas
 - configuração de redundância nos Pods para balanceamento de carga;
 - Sensores de SIEM e XDRs
- **VMs e Containers (exclusivamente):**
 - Hardening de Host/Guest: Configuração de SO enxuto (minimal) e desativação de serviços desnecessários;
 - Segurança de Acesso: Proibição de login de root via SSH e autenticação exclusiva por par de chaves;
 - Isolamento de Rede: Containers operando em redes virtuais apartadas (Micro-segmentação);
 - Alta Disponibilidade: Configuração de redundância em Pods e balanceamento de carga nativo;
 - Sensores de SIEMs/XDRs
- **Segurança de Endpoints (Clients):** Implementação de modelos *Zero Trust* com MFA obrigatório, criptografia de disco e controlo de acesso à rede (NAC 802.1X)

para garantir a conformidade dos dispositivos.

- Gestão de Identidade e Acesso (IAM - Zero Trust);
- MFA Obrigatório;
- Criptografia de Disco;
- NAC (Network Access Control - 802.1X) para garantir que apenas dispositivos com certificados digitais válidos e conformidade de segurança (patching em dia, EDR ativo) possam se conectar à rede;
- MDM / UEM (Unified Endpoint Management): Garantir que o sistema operacional esteja atualizado e com as configurações de segurança (GPOs) aplicadas antes de permitir o acesso ao Data Domain;
- Sensores de SIEM e XDR;
- **Proteção de Dados em Databases e Estações:** Aplicação de RBAC (Controle de Acesso Baseado em Funções), criptografia em repouso e auditoria detalhada de consultas às bases de dados.
 - RBAC (Role-Based Access Control): Acesso estritamente limitado por função de usuário/aplicação;
 - Criptografia em Repouso (At-Rest): Garantir que os dados no disco estejam cifrados
 - Auditoria de Consultas (AAA): Logs detalhados de quem acessou qual dado e quando (Audit Trail);
 - DLP (Data Loss Prevention) para evitar perda de dados, com bloqueio na transferencia de dados e monitoramento de tráfego de dados;
 - Sensores de SIEM e XDRs

5. Monitoramento de Servidores e Estações (Data Domain)

Sendo uma continuação de data domain, neste trecho o objetivo é tratar exclusivamente de hosts na rede

- **Servidores:** SServidores on premise conectados à rede, servindo de redundância e também para disponibilizar serviços específicos.
 - LDAP e RBAC -> com foco em permitir autenticação dos usuários ao sistema,
 - VPN -> para tunelar o tráfego externo;

- Modelo AAA -> para garantir a integridade do ambiente, assim como disponibilizar recursos de auditoria
- Sensores para SIEMs e XDRs
- **Estações:** Inserção de agentes/sensores que permitam monitorar dados, processos e demais elementos do ambiente.
 - Gestão de Identidade e Acesso (IAM - Zero Trust);
 - MFA Obrigatório;
 - Criptografia de Disco;
 - NAC (Network Access Control - 802.1X) para garantir que apenas dispositivos com certificados digitais válidos e conformidade de segurança (patching em dia, EDR ativo) possam se conectar à rede;
 - MDM / UEM (Unified Endpoint Management): Garantir que o sistema operacional esteja atualizado e com as configurações de segurança (GPOs) aplicadas antes de permitir o acesso ao Data Domain;
 - Sensores de SIEM e XDR;

6. Monitorização, Detecção e Resposta (SIEM, EDR & XDR)

A última camada garante a visibilidade transversal e a capacidade de reação a incidentes.

- **EDR/XDR:** Monitorização de processos em tempo real em servidores e estações de trabalho, permitindo o isolamento de hosts infectados e a remediação automática de ameaças como *ransomware*.
 - Monitoramento de Processos: Registro de cada execução de binários, scripts e comandos (Powershell, Bash) para detectar anomalias;
 - Análise de Árvore de Processos: Identificar se um processo legítimo (como o Word ou um Navegador) gerou um processo suspeito (como um terminal);
 - Isolamento de Host: Capacidade de "cortar" a rede do dispositivo infectado remotamente para conter um surto de malware;
 - Remediação: Rollback de alterações feitas por ransomware ou remoção automática de persistências no registro/arquivos;
 - Visibilidade Transversal: Unificar a visão do que acontece no "Client" com o que o "WAF" e o "CDN" estão vendo;
 - Resposta Orquestrada: Se o XDR detecta um ataque no servidor Python

(Uvicorn), ele pode automaticamente instruir o Firewall de Borda a bloquear o IP do atacante;

- Threat Hunting: Ferramentas de busca proativa por ameaças baseadas em IOCs (Indicadores de Comprometimento) globais.
- **SIEM:** Centralização e correlação de logs de todas as camadas anteriores (WAF, Firewall, Bases de Dados), facilitando a conformidade normativa e a perícia digital pós-incidente.
 - Centralização de Logs (Log Management): Coletar eventos do Roteador, NGFW, WAF, Bancos de Dados e Cloudflare em um único local;
 - Correlação de Eventos: Identificar que um erro de login no Banco de Dados (Data Domain) está relacionado a um tráfego suspeito detectado pelo WAF minutos antes;
 - Dashboard de Conformidade: Gerar relatórios automáticos para auditorias de conformidade (NIST, ISO 27001);
 - Retenção de Dados: Armazenamento histórico de logs para perícia digital (Forensics) após um incidente.

7. Conclusão

A arquitetura proposta oferece uma visão holística da segurança da informação, alinhando controles técnicos rigorosos com as melhores práticas internacionais. A integração entre as barreiras de proteção e os sensores de monitorização permite uma resposta coordenada, reduzindo significativamente a superfície de ataque da organização.